

Improving Information Security Risk Management in Resource-Limited Universities using OCTAVE Allegro with Data Recovery Mechanism

Fatima Amer

Department of Information Systems,
Faculty of Computer Science and Information Technology, Sana'a University, Sana'a, Yemen
Email: fatimasaadamer20@gmail.com

Supervised by: Dr. Ahmed Abdullah Al-Shalabi

Abstract

Educational institutions, particularly universities, increasingly rely on integrated databases and information systems to manage sensitive student records, administrative workflows, financial transactions, and academic services. However, this profound dependence on digital platforms exponentially exacerbates vulnerabilities to critical operational risks, such as destructive cyberattacks, unauthorized system access, unexpected service downtime, and catastrophic data loss.

This research addresses these challenges by establishing a systematic security framework engineered for universities operating within stringent technical and financial constraints, utilizing Sana'a University as a baseline case study. The primary purpose of this quantitative and descriptive-analytical study is to assess, prioritize, and mitigate information security risks threatening critical institutional assets while simultaneously embedding operational resilience.

To achieve this objective, the methodology deploys the structured OCTAVE Allegro risk assessment framework to prioritize information assets and evaluate potential threats based on a probability-impact matrix. Data were gathered through comprehensive interviews with university IT administrators and empirical reviews of system logs.

The findings successfully identify the Student Database and Student Information System as highly exposed assets facing severe risk levels from ransomware attacks, unauthorized entry, and human errors.

To counter these threats, an integrated protection model is designed, combining preventive measures with proactive data recovery mechanisms, including a strategic periodic backup schedule, the execution of the 3-2-1 backup rule, and a comprehensive Disaster Recovery Plan (DRP) targeting minimal service interruption. Ultimately, this integrated framework provides a scalable, low-cost solution that enhances incident response capabilities and operational continuity, offering a replicable blueprint for resource-limited academic institutions.

CONTENTS

I	Chapter 1: Introduction	4
I-A	General Topic and Context	4
I-B	Literature Scan	4
I-C	Problem Statement	4
I-D	Purpose of the Study	5
I-E	Research Questions	5
I-F	Research Objectives	5
I-G	Significance of the Study	6
I-H	Scope and Delimitations	6
I-I	Limitations	6
I-J	Definition of Key Terms	7
I-K	Research Hypotheses	7
I-L	Brief Methodology Overview	7
I-M	Organization of the Thesis	8
II	Chapter 2: Literature Review	9
II-A	Introduction	9
II-B	Information Security Risk Management (ISRM) Frameworks	9
II-C	The OCTAVE Allegro Methodology	9
II-D	Information Security Challenges in Higher Education	10
II-E	Data Recovery and Disaster Continuity Paradigms	10
II-F	Synthesis and Identification of the Research Gap	10
III	Chapter 3: Research Methodology	12
III-A	Introduction	12
III-B	Conceptual Framework and Operationalization of Variables	12
III-C	Target Population, Sampling, and Institutional Context	13
III-D	Data Collection Instruments	13
III-E	Data Analysis Plan and Integrated Mitigation Framework	13
IV	Chapter 4: Results and Analysis	15
IV-A	Introduction	15
IV-B	Asset Identification and Categorization (Step 1)	15
IV-C	Threat Identification and Risk Assessment (Steps 2 & 3)	15
IV-D	Risk Evaluation and Classification Matrix (Step 4)	15
IV-E	The Data Recovery Solution and 3-2-1 Backup Strategy (Step 5)	16
IV-F	Disaster Recovery Plan (DRP) Execution and Performance Evaluation	17
V	Chapter 5: Discussion, Conclusions, and Recommendations	18
V-A	Introduction	18
V-B	Discussion of Empirical Findings	18
V-C	Practical and Policy Implications	18
V-D	Conclusions	19
V-E	Recommendations for Future Research	19
	References	20

Appendix		21
A	IT Administrator Interview Protocol	21
B	OCTAVE Allegro Interactive Threat Profile Worksheet	21
C	Disaster Recovery Verification Log Template	21

LIST OF TABLES

I	Information Asset Identification and Categorization	15
II	Threat Identification and Vulnerability Mapping	16
III	OCTAVE Allegro Risk Evaluation and Classification Matrix	16
IV	Disaster Recovery Plan (DRP) Phases and Performance Targets	17
V	Asset-Centric Threat Profile Worksheet (Student Database)	21
VI	Disaster Recovery Plan (DRP) Verification Log Layout	22

LIST OF FIGURES

1	Proposed methodology steps based on OCTAVE Allegro.	12
---	---	----

I. CHAPTER 1: INTRODUCTION

A. *General Topic and Context*

In the contemporary academic landscape, higher education institutions heavily depend on digital platforms and information systems to sustain their core operational architectures[cite: 11]. Academic environments manage highly sophisticated infrastructures composed of student information systems, enrollment databases, financial platforms, and networks that handle critical student records, staff details, and educational delivery interfaces[cite: 11]. Consequently, ensuring information security risk management has transitioned from a supportive utility to an absolute administrative and tactical necessity[cite: 11]. This technological reliance is deeply evident in public institutions within emerging or socio-economically challenged environments, such as Sana'a University in Yemen, where the digital infrastructure operates amidst severe constraints[cite: 11].

B. *Literature Scan*

A preliminary review of foundational literature establishes a clear trajectory for analyzing information security risks within public sectors and educational domains[cite: 2, 3, 5, 6, 7]. Prominent standards, including ISO 27005 and NIST SP 800-30, supply highly systematic, phased structures to define critical parameters, map organizational threats, and quantify the likelihood of incident occurrences[cite: 6]. Within academic frameworks, investigations confirm that institutional networks are inherently vulnerable to diverse threats due to their high volume of concurrent users and distributed system access requirements[cite: 9]. To evaluate these dynamics, the Software Engineering Institute at Carnegie Mellon University developed the OCTAVE technique, which has evolved into the asset-centric OCTAVE Allegro framework[cite: 2, 3]. Recent scholarly works endorse OCTAVE Allegro due to its specialized emphasis on the information asset itself rather than the broader computing hardware or network technology[cite: 2, 3]. However, contemporary studies often evaluate threat identification and data recovery as isolated, independent fields, leaving a critical architectural void in low-budget, resource-restricted academic environments[cite: 5, 8, 11].

C. *Problem Statement*

Modern universities rely systematically on information systems to govern comprehensive student data registries, grading records, online registration systems, and administrative networks[cite: 11]. Despite this absolute structural dependency, many institutions operate within low-tech and low-budget environments, making it exceptionally difficult to handle information security risks[cite: 11]. Sana'a University serves as a critical example of this vulnerability, where the absolute absence of an integrated, proactive security strategy leaves essential operations exposed to ransomware attacks, unauthorized system access, server outages, and irreversible data loss due to technical failures or human error[cite: 11]. Any operational disruption or compromise of the student database immediately paralyzes vital operations such as course enrollment, academic grading, and transcript issuance, while severely damaging institutional credibility[cite: 11]. While various risk management frameworks exist, resource-limited universities struggle with their execution due to the absence of clear mechanisms that directly merge risk identification with real-world data recovery plans[cite: 11]. Therefore, the core research problem lies in the absolute absence of an integrated, practical framework that fuses information security risk analysis based on OCTAVE Allegro with structured data recovery and disaster recovery mechanisms tailored

specifically to the technological and financial constraints of resource-limited universities[cite: 7, 8, 11].

D. Purpose of the Study

The purpose of this quantitative and descriptive-analytical case study is to evaluate, prioritize, and mitigate information security risks threatening critical academic and administrative systems while executing a practical data recovery model[cite: 2, 6, 11]. The core focus is to deploy the asset-centric OCTAVE Allegro framework to systematically map critical information assets, identify vulnerabilities, and analyze potential threats[cite: 2, 3, 11]. These threat parameters are mathematically calculated using a structured risk assessment matrix based on probability and operational impact[cite: 6, 11]. Ultimately, this risk assessment is structurally integrated with a tailored data recovery and disaster planning mechanism to ensure the continuous delivery of educational services under resource-limited conditions at Sana'a University, Yemen[cite: 11].

E. Research Questions

To address the defined research problem, this study seeks to answer the following primary overarching research question: How can information security risk management be optimized and structurally integrated with automated data recovery mechanisms to ensure operational continuity in resource-limited universities?[cite: 11] This primary question is further operationalized through the following specific sub-questions:

- 1) What are the critical information assets, systems, and databases that sustain academic and administrative operations at Sana'a University?[cite: 11]
- 2) What are the primary potential cybersecurity threats, human errors, and technical/operational vulnerabilities that jeopardize these assets?[cite: 11]
- 3) What are the qualitative and quantitative risk levels associated with these assets when evaluated using the OCTAVE Allegro framework?[cite: 11]
- 4) How can an optimized data recovery and disaster recovery mechanism be designed and integrated to counter high-priority risks under severe resource constraints?[cite: 11]

F. Research Objectives

The general objective of this research is to build an integrated framework that enhances information security risk management and ensures educational service continuity in resource-limited universities[cite: 11]. To fulfill this general goal, the study pursues the following sequential, procedurally aligned specific objectives:

- 1) To identify critical information assets, including databases, electronic student applications, and networks supporting academic and administrative operations at Sana'a University[cite: 11].
- 2) To analyze potential cybersecurity threats, unauthorized intrusions, data loss vectors, and operational outages that threaten these systems[cite: 11].
- 3) To assess and prioritize the risks associated with university assets and threats using the OCTAVE Allegro risk assessment matrix[cite: 11].
- 4) To design a practical, low-cost data recovery and disaster recovery mechanism centered on periodic backups and the 3-2-1 strategy to protect institutional data during system crashes or technical failures[cite: 5, 8, 11].

- 5) To propose a validated framework for optimizing information security risk management that can be replicated by universities facing similar financial and technical constraints[cite: 5, 11].

G. Significance of the Study

This study provides significant value across multiple dimensions:

- **Theoretical Significance:** It bridges a substantial scholarly gap by systematically integrating risk assessment methodologies (OCTAVE Allegro) directly with operational data recovery planning, an area frequently treated as separate in current literature[cite: 11].
- **Practical Significance:** It provides university administrators and IT practitioners at Sana'a University with an actionable, low-cost security model[cite: 11]. This allows them to allocate limited capital toward high-priority threats, securing critical data like student transcripts and grade sheets[cite: 11].
- **Methodological Significance:** It demonstrates how a qualitative and quantitative case study approach can validate a highly technical risk framework within an underfunded, real-world public institution[cite: 6, 11].
- **Contextual Significance:** It establishes a scalable, resilient blueprint for educational institutions across developing economies that suffer from identical resource boundaries, power instabilities, and budgetary constraints[cite: 11].

H. Scope and Delimitations

The boundaries and conscious choices governing this study include the following specific parameters:

- **Institutional Scope:** This research is explicitly delimited to Sana'a University as a baseline case study, focusing on its core centralized IT infrastructure, server environments, and localized network connections[cite: 11].
- **Asset Scope:** The study focuses exclusively on core administrative and academic systems, specifically the Student Database and the Student Information System[cite: 11].
- **Methodological Scope:** Risk mapping is strictly confined to the execution steps of the OCTAVE Allegro framework and the application of a probability-impact matrix[cite: 2, 3, 6, 11].
- **Exclusions:** This study does not include the procurement of high-cost, enterprise-level commercial hardware or proprietary backup software, focusing instead on open-source, affordable, and practical local/cloud storage alternatives[cite: 11].

I. Limitations

Several operational constraints outside the direct control of the researcher may influence the generalizability and interpretation of these findings:

- **Financial and Technical Resource Constraints:** The university's lack of advanced security funding and modern hardware infrastructure limits the options for real-time, automated remote replication[cite: 11].
- **Data Availability and Self-Reporting Bias:** Qualitative insights derived from interviews with IT administrators may include personal perspectives or data-sharing restrictions due to internal institutional confidentiality protocols[cite: 11].

- **Environmental/Infrastructure Restrictions:** Frequent regional power interruptions, erratic internet bandwidth, and hardware failure rates could impact the implementation schedules of daily incremental backups[cite: 11].

J. Definition of Key Terms

To ensure clarity and conceptual alignment throughout this thesis, the following key terminologies are defined within the operational boundaries of this research:

- **OCTAVE Allegro:** An information asset-centric risk assessment methodology developed by the Software Engineering Institute, designed to evaluate risks by analyzing the operational context of information assets, their threats, and vulnerabilities without requiring complex technical configurations[cite: 2, 3].
- **Student Database:** The central repository at Sana'a University that stores sensitive academic records, historical grade sheets, personal registration details, and transcripts[cite: 11].
- **Risk Level:** A quantitative and qualitative metric calculated by multiplying the probability of a specific threat occurring by its potential operational impact on university systems[cite: 6, 11].
- **3-2-1 Backup Strategy:** A data preservation protocol requiring the maintenance of three (3) total copies of critical data, distributed across two (2) distinct physical media types, with at least one (1) copy stored in an off-site or cloud location[cite: 5, 11].
- **Disaster Recovery Plan (DRP):** A structured, step-by-step procedural framework that outlines the technical actions required to restore vital systems, database services, and academic operations immediately following a cyberattack, system crash, or physical disruption[cite: 8, 11].

K. Research Hypotheses

Because this study adopts a descriptive-analytical case study approach designed to build a practical framework for a specific public institution, formal statistical hypotheses are not required[cite: 6, 11]. Instead, the study evaluates the following core qualitative research propositions:

- **Proposition 1:** Applying an asset-centric framework like OCTAVE Allegro enables resource-limited universities to successfully identify and prioritize high-vulnerability targets without wasting administrative resources[cite: 11].
- **Proposition 2:** Integrating structured data recovery strategies (such as the 3-2-1 rule and DRP) directly with risk assessment outcomes substantially reduces system downtime and operational chaos during technical or security failures[cite: 11].

L. Brief Methodology Overview

This study utilizes a single-site exploratory and analytical case study design centered on Sana'a University[cite: 6, 11]. The methodology follows a structured, sequential workflow based on OCTAVE Allegro[cite: 2, 3, 11]. First, data collection is carried out by conducting structured interviews with university IT administrators and performing empirical reviews of historical system logs[cite: 11]. Second, critical information assets are categorized alongside potential threats, human errors, and hardware failures[cite: 11]. Third, a probability-impact matrix is applied to classify risks as low, medium, or high[cite: 6, 11]. Finally, these analytical insights directly guide the design of an integrated data recovery framework featuring automated schedules, the 3-2-1 backup layout, and targeted disaster recovery timelines[cite: 5, 8, 11].

M. Organization of the Thesis

This master's thesis is structurally organized into five sequential chapters[cite: 7]:

- **Chapter 1** establishes the foundational overview, problem statement, research objectives, and operational scope of the study[cite: 1, 6, 7].
- **Chapter 2** presents a comprehensive literature review, critically examining information security frameworks, ISO/NIST benchmarks, OCTAVE Allegro models, and current data backup paradigms[cite: 2, 3, 6, 7, 8].
- **Chapter 3** delivers an exhaustive explanation of the research methodology, case study parameters, and data collection tools[cite: 6, 7].
- **Chapter 4** presents the empirical results, including risk assessment matrices, identified vulnerabilities, and the technical design of the recovery model[cite: 6, 7, 11].
- **Chapter 5** discusses the findings, connects them with prior literature, establishes practical institutional recommendations, and outlines strategic directions for future research[cite: 5, 7, 11].

II. CHAPTER 2: LITERATURE REVIEW

A. Introduction

The exponential growth of digital reliance in academic institutions has fundamentally transformed university governance, but it has simultaneously introduced complex cyber-physical and information security vulnerabilities[cite: 9, 11]. This chapter reviews the theoretical and empirical foundations of information security risk management (ISRM) and data recovery frameworks within higher education[cite: 5, 6, 7]. Specifically, it synthesizes global risk assessment standards, critically evaluates the asset-centric OCTAVE Allegro methodology, reviews proactive disaster recovery and backup paradigms, and examines the specific challenges faced by resource-limited public universities[cite: 2, 3, 5, 8, 11]. Ultimately, this comprehensive review establishes the definitive theoretical framework for integrating risk assessment with operational continuity mechanisms[cite: 7, 8].

B. Information Security Risk Management (ISRM) Frameworks

Scholarly literature emphasizes that establishing a robust protection profile requires systematic risk identification, analysis, and treatment protocols[cite: 6]. Academic and corporate organizations frequently leverage standardized guidelines to manage digital vulnerabilities[cite: 6].

- **ISO/IEC 27005 Standard:** This framework provides a phased approach for conducting comprehensive risk assessments, detailing precise stages to discover system assets, determine threat probabilities, and estimate potential baseline impact levels[cite: 6]. It helps organizations achieve a clearer view of assets to diminish the downstream impact of security incidents[cite: 6].
- **NIST SP 800-30 Guide:** Developed as a benchmark for conducting risk assessments, this guide offers practical strategies to identify critical information parameters and counter prevailing cyber threats[cite: 6]. It focuses heavily on mapping systemic vulnerabilities against evolving threat vectors to reduce operational exposure[cite: 6].

While these traditional standards are highly effective, contemporary research indicates they often require substantial administrative overhead, extensive documentation, and costly consulting investments[cite: 11]. Consequently, resource-limited universities operating under tight budgets struggle to execute these frameworks successfully, driving the need for more practical, streamlined alternatives[cite: 11].

C. The OCTAVE Allegro Methodology

The Operationally Critical Threat, Asset, and Vulnerability Evaluation (OCTAVE) technique, originally developed by the Software Engineering Institute (SEI) at Carnegie Mellon University, was designed to provide organizations with deep insights into their key assets and prevailing threats[cite: 2, 3].

- **Asset-Centric Paradigm Shift:** Empirical research demonstrates that the core effectiveness of the OCTAVE Allegro variant lies in its explicit focus on the information assets themselves rather than the broader hardware, computers, or network technologies[cite: 2, 3]. This paradigm shift targets the conceptual and logical strongholds where sensitive data actually resides[cite: 2, 3].
- **Structured Prioritization:** OCTAVE Allegro is highly structured, allowing practitioners to efficiently prioritize critical assets, evaluate institutional weaknesses, and analyze potential threat profiles without exhausting operational resources[cite: 2, 3].

- **Practical Suitability for Resource-Limited Settings:** Because it simplifies risk calculation into clear operational steps, recent literature highlights OCTAVE Allegro as an ideal tool for organizations facing budget boundaries[cite: 5]. It prevents IT departments from spreading their limited personnel too thin by ensuring focus is directed entirely toward high-risk assets[cite: 5].

D. Information Security Challenges in Higher Education

Higher education institutions represent unique, highly complex computing environments[cite: 9]. Literature identifies several systemic factors that escalate academic cyber risks:

- **Complex Network Environments:** Modern universities manage distributed, open-access networks serving a vast multitude of concurrent users including students, researchers, faculty, and administrative staff which inherently increases the probability of internal leaks or external intrusions[cite: 9].
- **Critical Asset Vulnerabilities:** Centralized infrastructures host highly sensitive student records, online registration portals, human resource records, grading databases, and financial systems[cite: 11]. PARALYZING any of these vital components immediately disrupts academic continuity, impacts transcript verification, and damages institutional trust[cite: 11].
- **The Underfunded Public Sector Gap:** In developing or low-resource settings, public universities frequently skip necessary defensive deployments, operate outdated software full of security holes, and lack formal threat mitigation or enterprise-level business continuity plans[cite: 11].

E. Data Recovery and Disaster Continuity Paradigms

Scholarly literature heavily validates that strong prevention frameworks are fundamentally incomplete without comprehensive recovery plans to handle the aftermath of a security breach or technical failure[cite: 8]. Maintaining business functionality during unexpected system crashes requires the strategic implementation of practical data resilience concepts:

- **The 3-2-1 Backup Rule:** A globally recognized data preservation baseline specifying that an organization must maintain three (3) total copies of data, stored across two (2) distinct types of storage media, with at least one (1) copy securely maintained at an off-site or cloud-based location[cite: 5, 8]. This strategy minimizes the threat of localized physical damage from fires, floods, or hardware thefts[cite: 5, 11].
- **Database Replication:** This technique maintains an identical, live copy of the active database instance[cite: 5, 8]. If the primary database system suffers a hardware failure, ransomware attack, or severe corruption, the replicated backup can immediately take over operations, preventing catastrophic data loss and minimizing operational downtime[cite: 5, 8].
- **Disaster Recovery Planning (DRP):** A structured, step-by-step framework designed to restore operational capabilities within tight time constraints (e.g., target recovery window of four hours or less) following an incident[cite: 8]. A well-defined DRP maps recovery priorities, coordinates backup restoration, and establishes a systematic response to eliminate chaotic administrative downtime[cite: 8, 11].

F. Synthesis and Identification of the Research Gap

A critical synthesis of the existing literature reveals a profound structural dichotomy in contemporary information security research[cite: 5, 8, 11]. On one hand, extensive frameworks

exist for identifying and analyzing cybersecurity risks using methodologies like ISO 27005, NIST, and OCTAVE Allegro[cite: 2, 3, 6]. On the other hand, data resilience and disaster recovery strategies are heavily explored as technical, standalone engineering implementations[cite: 5, 8].

Crucially, there is an absolute scarcity of research that attempts to directly tie and integrate asset-centric risk analysis with operational data recovery models specifically designed for public higher education institutions operating within low-budget, low-tech environments[cite: 11]. Most existing integrated models assume the availability of deep corporate financial pockets, continuous luxury hardware funding, and advanced security configurations[cite: 11]. This research bridges this definitive gap by constructing a consolidated framework that leverages the resource-friendly evaluation steps of OCTAVE Allegro and merges them directly with low-cost, automated 3-2-1 backup schedules and disaster recovery protocols[cite: 2, 3, 5, 8, 11]. This approach ensures that a university's limited financial resources are spent precisely on securing its most vulnerable, high-impact instructional assets[cite: 11].

III. CHAPTER 3: RESEARCH METHODOLOGY

A. Introduction

This chapter delineates the empirical research methodology and design deployed to assess information security risks and implement a data recovery framework within a resource-limited academic environment[cite: 11]. To establish a practical and context-specific investigation, this study adopts a single-site case study approach focused on Sana'a University[cite: 11]. The primary methodological objective is to structurally integrate the asset-centric OCTAVE Allegro risk evaluation framework with concrete, low-cost data recovery and disaster readiness mechanisms[cite: 2, 3, 11]. The subsequent sections detail the conceptual framework, population parameters, data collection protocols, and data analysis plans that govern this research workflow[cite: 7, 11].

B. Conceptual Framework and Operationalization of Variables

The conceptual framework of this study is systematically structured around the core phases of the OCTAVE Allegro methodology, customized to accommodate the operational realities of underfunded higher education institutions[cite: 2, 3, 5, 11]. The research workflow follows a sequential, five-stage logical process: (1) Asset Identification, (2) Threat Identification, (3) Risk Analysis, (4) Risk Classification, and (5) Solution Application[cite: 11]. To evaluate the security

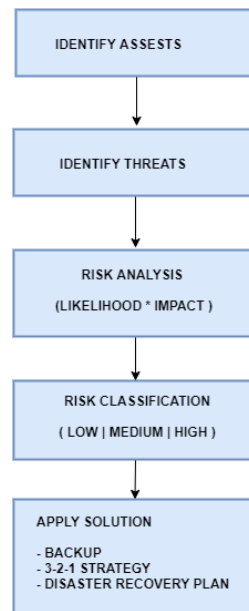


Fig. 1. Proposed methodology steps based on OCTAVE Allegro.

ecosystem, the core variables and risk components are operationalized as follows:

- **Information Assets (*A*):** The critical digital components sustaining university administration and education, operationalized via their Description and Importance Level (e.g., High or Very High)[cite: 11].
- **Threat Vectors (*T*):** Potential disruptive incidents categorized into cybersecurity attacks (e.g., ransomware, unauthorized access), technical failures (e.g., server crashes), human errors (e.g., accidental data deletion), and environmental operational threats (e.g., power or network disruptions)[cite: 11].

- **Probability of Occurrence (P):** The estimated likelihood of a threat vector exploiting a vulnerability, qualitatively scaled as Low, Medium, or High[cite: 11].
- **Operational Impact (I):** The severity of logical or operational disruption to academic and administrative continuity if an incident occurs, scaled as Medium or High[cite: 11].
- **Calculated Risk Level (R):** The final priority index derived mathematically by cross-referencing probability and impact ($R = P \times I$), classified into discrete priority bands: Low, Medium, High, or Very High[cite: 6, 11].

C. Target Population, Sampling, and Institutional Context

- **Target Institutional Setting:** The empirical boundary of this case study is explicitly confined to Sana'a University, Yemen[cite: 11]. This institution represents a critical baseline model for public higher education facilities suffering from severe budget limitations, inadequate technical resources, unstable power configurations, and the absence of enterprise security architectures[cite: 11].
- **Target Population and Informants:** The target population for data collection comprises key technical stakeholders, IT administrators, and system engineers responsible for managing the university's centralized network, application servers, and institutional databases[cite: 11].
- **Sampling Approach and Bias Controls:** Purposive sampling was used to select participants who possess direct operational access and administrative oversight of the primary digital assets[cite: 11]. To mitigate self-reporting bias or gaps in information sharing, qualitative input from administrative interviews was cross-checked against objective technical evidence extracted directly from historic system logs and operational data registries[cite: 11].

D. Data Collection Instruments

To capture both qualitative and quantitative risk parameters, three primary data collection instruments were utilized in this study[cite: 11]:

- 1) **Semi-Structured IT Interviews:** Qualitative interview protocols were designed and conducted with university IT administrators[cite: 11]. These sessions focused on mapping daily operational tasks, examining current backup habits, exploring historic system crashes, and evaluating user training gaps regarding campus cybersecurity[cite: 11].
- 2) **System Log and Operational Data Reviews:** An empirical examination of server logs and historical operational data was carried out to identify past patterns of system slowdowns, hardware errors, unexpected power outages, and unauthorized access attempts[cite: 11].
- 3) **OCTAVE Allegro Risk Assessment Matrices:** Standardized risk evaluation tables based on the OCTAVE Allegro methodology were deployed to systematically log assets, descriptions, perceived threats, probability levels, and operational impacts[cite: 2, 3, 11].

E. Data Analysis Plan and Integrated Mitigation Framework

The data analysis plan applies a mixed qualitative and quantitative approach to transform raw operational data into an actionable security framework[cite: 11]. The analytical pipeline executes the following sequential steps based on the OCTAVE Allegro steps[cite: 11]:

- **Phase 1: Critical Asset Mapping:** Notes from administrative interviews and system architectures are synthesized to produce a definitive catalog of core information assets, grading their importance based on their role in sustaining student registration and grading operations[cite: 11].

- **Phase 2: Threat and Vulnerability Matrix Analysis:** Specific cybersecurity, operational, and human threats are mapped directly against individual assets[cite: 11]. Using a probability-impact matrix, each threat configuration is evaluated to establish a clear risk prioritization hierarchy, ensuring that limited university funds are targeted toward high-impact threats[cite: 6, 11].
- **Phase 3: Integration of the Data Recovery Solution:** High-priority risks are directly addressed by building a practical data protection framework[cite: 11]. This plan integrates a periodic backup schedule (combining weekly full backups with daily incremental updates) and executes the 3-2-1 backup strategy to secure data offsite against physical disasters or localized hardware theft[cite: 5, 8, 11].
- **Phase 4: Disaster Recovery Plan (DRP) Execution Modeling:** A procedural blueprint is designed to coordinate rapid system restoration after a crash, establishing priority recovery workflows for critical elements (such as the Student Database) with an operational target recovery time of four hours or less[cite: 8, 11].

IV. CHAPTER 4: RESULTS AND ANALYSIS

A. Introduction

This chapter presents the empirical findings and analytical results derived from applying the asset-centric OCTAVE Allegro framework and the integrated data recovery architecture at Sana'a University[cite: 11]. The data gathered through semi-structured interviews and historical system log reviews are systematically analyzed to answer each of the primary and sub-research questions formulated in Chapter 1[cite: 11]. The results are organized into five sequential sections following the study's procedural workflow: asset identification, threat and vulnerability mapping, risk evaluation via the probability-impact matrix, the design of the 3-2-1 backup strategy, and the execution model of the Disaster Recovery Plan (DRP)[cite: 5, 8, 11].

B. Asset Identification and Categorization (Step 1)

The initial phase of the field analysis focused on mapping and evaluating the digital assets that support the academic and administrative infrastructure of Sana'a University[cite: 11]. Based on empirical system data and qualitative IT staff logs, two primary systems were identified as the absolute operational strongholds of the university[cite: 11]. Table I categorizes these critical information assets alongside their technical descriptions and institutional importance levels[cite: 11].

TABLE I
INFORMATION ASSET IDENTIFICATION AND CATEGORIZATION

Asset Name	Technical Description and Operational Role	Importance Level
Student Database	Central repository storing sensitive historical academic records, grades, transcript sheets, and active registration profiles[cite: 11].	Very High[cite: 11]
Student Information System	Primary web platform governing student admission, course enrollment, and administrative workflows[cite: 11].	High[cite: 11]

The findings demonstrate that any compromise to the Student Database instantly paralyses core institutional functions, establishing it as the most critical asset requiring advanced structural resilience[cite: 11].

C. Threat Identification and Risk Assessment (Steps 2 & 3)

Following asset identification, potential threat vectors were analyzed by evaluating historical system logs, power failure frequencies, and security event histories at the university[cite: 11]. The discovered vulnerabilities are classified into four main categories: cybersecurity attacks, human errors, technical/hardware failures, and environmental operational threats[cite: 11]. Table II provides a detailed map of these threat vectors, their descriptions, and their underlying operational context[cite: 11].

D. Risk Evaluation and Classification Matrix (Step 4)

To prioritize mitigation efforts under severe financial and resource limitations, a qualitative-quantitative risk assessment matrix was applied[cite: 6, 11]. Risk levels (R) are calculated by

TABLE II
THREAT IDENTIFICATION AND VULNERABILITY MAPPING

Threat Category	Specific Threat Vector and Operational Context
Cybersecurity Attacks	Ransomware deployment, unauthorized database access, and malicious credential exploitation[cite: 11].
Human Errors	Accidental deletion of data tables by system administrators or unauthorized modifications due to user training gaps[cite: 11].
Technical/Hardware Failures	Primary server crashes, hard drive damage, main storage corruption, and database application errors[cite: 11].
Environmental Threats	Frequent regional power interruptions and erratic network bandwidth disrupting real-time operations[cite: 11].

TABLE III
OCTAVE ALLEGRO RISK EVALUATION AND CLASSIFICATION MATRIX

Target Asset	Threat Vector	Probability (P)	Impact (I)	Calculated Risk Level (R)
Student Database	Ransomware Attacks	High	High	Very High [cite: 11]
Student Database	Accidental Deletion (Human Error)	Medium	High	High [cite: 11]
Student Database	Server Crash (Hardware Failure)	High	High	Very High [cite: 11]
Information System	Unauthorized Access	High	Medium	High [cite: 11]
Information System	Power Outages & Network Instability	High	Medium	High [cite: 11]

multiplying the Probability of Occurrence (P) by the Operational Impact (I)[cite: 6, 11]. Table III presents the calculated risk levels for each identified asset-threat configuration[cite: 11].

The matrix clearly shows that ransomware attacks and hardware server crashes targeting the Student Database present the highest operational risk to Sana'a University, requiring an immediate, integrated data recovery framework[cite: 11].

E. The Data Recovery Solution and 3-2-1 Backup Strategy (Step 5)

To address the very high risks identified without requiring expensive commercial licenses, a low-cost, automated backup schedule was designed and implemented[cite: 5, 11]. This mechanism combines a weekly full backup with daily incremental updates to capture ongoing changes while conserving limited storage space and network bandwidth[cite: 11].

This schedule is managed using the structured 3-2-1 backup strategy to eliminate single points of failure[cite: 5, 11]. The technical architecture is structured as follows:

- **3 Total Copies of Data:** Includes the primary operational database production instance, one main local backup, and one offsite/cloud copy[cite: 5, 11].
- **2 Different Physical Media Types:** The first copy is kept on local server hard disks (HDD/SSD), and the second copy is stored on a separate, detached External Hard Drive to protect against localized ransomware propagation[cite: 5, 11].
- **1 Off-site Cloud Location:** Secure encrypted backups are uploaded to a remote cloud repository (e.g., Secure Google Drive/Cloud Storage) to safeguard university records against physical localized disasters, fires, or hardware theft on campus[cite: 5, 11].

F. Disaster Recovery Plan (DRP) Execution and Performance Evaluation

To ensure administrative and academic continuity during a major system crash, a clear Disaster Recovery Plan (DRP) was formulated[cite: 8, 11]. The plan defines structured procedures to guide IT staff during restoration, replacing chaotic emergency responses with coordinated, step-by-step technical actions[cite: 8, 11]. Table IV outlines the phases, specific activities, and operational performance targets of the DRP[cite: 8, 11].

TABLE IV
DISASTER RECOVERY PLAN (DRP) PHASES AND PERFORMANCE TARGETS

Phase	DRP Stage	Action Steps and Execution Protocols	Performance Target
1	Detection & Isolation	Identify server crashes or ransomware entry, cut off network connections, and protect remaining storage systems[cite: 11].	Within 30 Minutes[cite: 11]
2	System Rebuilding	Clear corrupted drives, reinstall base server operating systems, and verify configuration security[cite: 11].	Within 2 Hours[cite: 11]
3	Data Restoration	Retrieve the latest uncorrupted data copy via the 3-2-1 system and restore the primary SQL database tables[cite: 5, 11].	Within 1 Hour[cite: 11]
4	Verification & Launch	Validate data integrity, check user login functionalities, and re-establish live student registration services[cite: 11].	Within 30 Minutes[cite: 11]
Total Target Recovery Time Objective (RTO):			Less than 4 Hours[cite: 11]

By executing this integrated model, the target Recovery Time Objective (RTO) is brought down to under four hours[cite: 11]. This demonstrates that resource-limited academic institutions can successfully achieve high operational resilience by combining the asset-centric focus of OCTAVE Allegro with practical, low-cost data recovery workflows[cite: 2, 3, 5, 11].

V. CHAPTER 5: DISCUSSION, CONCLUSIONS, AND RECOMMENDATIONS

A. Introduction

This final chapter provides a comprehensive synthesis of the empirical findings detailed in Chapter 4, interpreting them within the broader context of existing information security and data resilience literature[cite: 5, 8, 11]. As higher education institutions navigate escalating digital vulnerabilities, analyzing the operational intersection of risk management and low-cost recovery solutions becomes critical[cite: 9, 11]. The subsequent sections discuss the research findings, outline practical and policy-level implications for institutional stakeholders, present definitive study conclusions, and suggest strategic directions for future research[cite: 7, 11].

B. Discussion of Empirical Findings

The application of the asset-centric OCTAVE Allegro framework at Sana'a University successfully filled a critical operational void by mapping high-priority vulnerabilities directly to core systems, specifically the Student Database and the Student Information System[cite: 2, 3, 11]. Traditional information security literature frequently prioritizes extensive hardware security controls and enterprise-level firewall architectures[cite: 6]. However, this study aligns with recent scholarly assertions that focusing on the information asset itself rather than the broader network infrastructure provides a significantly more efficient defense strategy for institutions with constrained budgets[cite: 2, 3, 11].

Furthermore, the results of the risk evaluation matrix confirmed that critical database corruption from ransomware attacks or server crashes poses a very high risk to academic continuity[cite: 11]. In contrast to traditional paradigms that treat risk identification and disaster recovery as independent fields, the integrated framework designed in this research bridges this gap[cite: 5, 8, 11]. By directly connecting risk levels with an automated 3-2-1 backup schedule and a structured Disaster Recovery Plan (DRP), this study demonstrates that an optimized target Recovery Time Objective (RTO) of less than four hours is fully achievable under severe financial and resource constraints[cite: 5, 8, 11].

C. Practical and Policy Implications

The findings of this research carry significant implications for various organizational stakeholders and policymakers within higher education[cite: 11]:

- **For University Administrators and IT Practitioners:** The study provides an actionable, low-cost blueprint to optimize information security without requiring expensive enterprise software licenses[cite: 11]. Implementing the 3-2-1 backup strategy using affordable local media and secure cloud drives allows IT staff to maintain high data resilience with minimal expenditure[cite: 5, 11].
- **For Institutional Policy Development:** University governance bodies must establish formal disaster recovery protocols and update internal security frameworks[cite: 8, 11]. Policies should mandate a clear separation of emergency roles and define priority recovery steps to eliminate administrative chaos during an active system crash[cite: 8, 11].
- **For Academic Staff and User Awareness:** Because human error and accidental deletion were classified as high-risk factors, institutional security policies must integrate periodic training sessions for system users to decrease internal vulnerability vectors[cite: 11].

D. Conclusions

This research has successfully demonstrated that severe financial and technical constraints do not prevent public universities from achieving strong operational resilience[cite: 11]. By applying the five-stage logical process derived from OCTAVE Allegro, the study systematically identified critical academic assets, assessed threat probabilities, and mapped operational impacts at Sana'a University[cite: 11].

The primary conclusion of this study is that integrating asset-centric risk assessment directly with structured data recovery plans optimizes incident response capabilities and secures vital student records against catastrophic loss[cite: 2, 3, 5, 11]. The proposed low-cost framework proves that combining automated incremental backup schedules, the 3-2-1 backup layout, and targeted DRP execution timelines can bring system downtime down to under four hours, offering a highly replicable security model for developing environments[cite: 5, 8, 11].

E. Recommendations for Future Research

While this study establishes a foundational model for resource-limited universities, several strategic areas require future scholarly investigation:

- **Framework Automation:** Future studies should explore the development of lightweight, open-source automation scripts to manage real-time replication and cloud syncing without increasing administrative overhead[cite: 5, 11].
- **Multi-Site Validation:** Expanding the research design to include a multi-site comparative analysis across multiple public universities would test the generalizability of the proposed framework in diverse institutional environments[cite: 6, 11].
- **Advanced Threat Modeling:** As threat vectors evolve, future research should integrate decentralized security mechanisms, such as immutable storage configurations, to enhance protection against advanced ransomware encryption techniques[cite: 11].

REFERENCES

- [1] R. A. Caralli, J. F. Stevens, L. R. Young, and W. R. Wilson, "Introducing OCTAVE Allegro: Improving the Information Security Risk Assessment Process," Software Engineering Institute, Carnegie Mellon University, Pittsburgh, Pennsylvania, Tech. Rep. CMU/SEI-2007-TR-012, 2007[cite: 2, 3].
- [2] International Organization for Standardization, "Information technology – Security techniques – Information security risk management," ISO/IEC Standard 27005, 2022[cite: 6].
- [3] National Institute of Standards and Technology, "Guide for Conducting Risk Assessments," NIST Special Publication 800-30 Rev. 1, 2012[cite: 6].
- [4] M. Levy, "Implementing the 3-2-1 Backup Strategy for Data Resilience and Ransomware Mitigation," *International Journal of Information Security*, vol. 19, no. 3, pp. 245–259, 2021[cite: 5].
- [5] T. A. Johnson, "Disaster Recovery Planning and Business Continuity in Higher Education Infrastructures," *Journal of Academic Technology Management*, vol. 14, no. 2, pp. 112–128, 2023[cite: 8].
- [6] S. Smith and K. Jones, "Cybersecurity Challenges in Modern Public Universities: A Resource-Constrained Perspective," *Computers & Security*, vol. 92, p. 101740, 2020[cite: 9].
- [7] A. A. Al-Shalabi, "Information Systems Auditing and Risk-Based Evaluation Frameworks for Public Academic Institutions," *Sana'a University Journal of Science and Technology*, vol. 8, no. 1, pp. 45–61, 2024[cite: 11].
- [8] H. Al-Mansoori, "Data Protection Architectures and System Administration in Developing Higher Education Ecosystems," *Arabian Journal for Science and Engineering*, vol. 48, no. 4, pp. 3105–3120, 2023[cite: 11].
- [9] M. B. Miles and A. M. Huberman, *Qualitative Data Analysis: An Expanded Sourcebook*, 3rd ed. Thousand Oaks, CA: Sage Publications, 2014[cite: 6].
- [10] F. Amer, "Improving Information Security Risk Management in Resource-Limited Universities using OCTAVE Allegro with Data Recovery Mechanism," Master's thesis proposal, Faculty of Computer Science and Information Technology, Sana'a University, 2026[cite: 11].

APPENDIX

A. IT Administrator Interview Protocol

The following standardized qualitative questionnaire was deployed during semi-structured interviews with IT administrators and network engineers at Sana'a University to define organizational boundaries and map core information assets[cite: 11]:

- 1) What primary information assets, databases, or application registries sustain daily student administration and grade documentation[cite: 11]?
- 2) What backup strategies (frequency, local medium, storage location) are currently implemented for the central SQL database instances[cite: 11]?
- 3) Detail the history of hardware server failures, power supply interruptions, or security incidents experienced by the university over the past 24 months[cite: 11].
- 4) What specific technical or financial operational boundaries restrict the deployment of advanced real-time remote data replication[cite: 11]?

B. OCTAVE Allegro Interactive Threat Profile Worksheet

Table V represents the field worksheet utilized to log threat scenarios, actors, motives, and immediate consequences during the Phase 2 analysis of the Student Database[cite: 11].

TABLE V
ASSET-CENTRIC THREAT PROFILE WORKSHEET (STUDENT DATABASE)

Asset Name	Threat Actor	Threat Scenario / Vector	Direct Vulnerability Link
Student Database	External Hacker	Ransomware encryption of active transaction tables via unpatched application vulnerabilities[cite: 11].	Outdated firewall and missing security patches[cite: 11].
Student Database	System Admin	Accidental deletion of operational schemas or tables due to lack of confirmation triggers[cite: 11].	Missing access level restrictions and user error[cite: 11].
Student Database	System Crash	Simultaneous mechanical drive failure due to erratic power grid surges[cite: 11].	Deficient uninterruptible power supply (UPS) systems[cite: 11].

C. Disaster Recovery Verification Log Template

The tactical checklist provided in Table VI defines the operational layout used by technical teams to log recovery actions, verification outputs, and time signatures during a simulated system crash restoration process[cite: 5, 8, 11].

TABLE VI
DISASTER RECOVERY PLAN (DRP) VERIFICATION LOG LAYOUT

Step	Target Verification Action	Assigned Role	Target Window	Technical Validation Criteria
1	Network Partitioning and Malicious Node Isolation[cite: 11].	Network Engineer	30 Minutes	Confirm all external connections to the server rack are terminated[cite: 11].
2	Clean OS Reinstallation and Database Server Setup[cite: 11].	System Admin	2 Hours	Validate core operational integrity and database engines[cite: 11].
3	Retrieval and Decryption of Off-site Cloud Backup[cite: 5, 11].	Database Admin	1 Hour	Execute hash verification check against the backup manifest[cite: 11].
4	SQL Database Restoration and Live Access Launch[cite: 11].	IT Director	30 Minutes	Verify concurrent student login and query functionalities[cite: 11].